SC3010 Computer Security

Tutorial 1 – Introduction & Software Security (I)

1. Circle the correct answers in the following questions.
    1) Which security properties do ransomware, spyware and backdoor aim to compromise, respectively

        A. Integrity, Confidentiality, Accountability.
        B. Availability, Confidentiality, Authenticity.
        C. Confidentiality, Accountability, Integrity.
        D. Integrity, Accountability, Availability.

    2) Which of the following statements is false?

        A. Security cannot be established in a computer system without trusting any components.
        B. A threat model should clearly define the TCB, adversary's capabilities and security properties to be achieved.
        C. The three security strategies to protect a system are detection, mitigation, and reaction.
        D. Defense in depth can increase the difficulty of attacking the entire system, but also the cost and complexity of implementing the system.

    3) Which of the following statements is false about buffer overflow attacks?

        A. Buffer overflow attacks could lead to privilege escalation.
        B. Buffer overflow attacks could affect the stack, heap, or even global data.
        C. Buffer overflow attacks could happen even when the target system does not receive untrusted data.
        D. NOP instruction is used to increase the chance of jumping to the malicious address when overwriting the return address with buffer overflow.

2. Answer the following questions.
    1) Use buffer overflow as an example to explain what do the vulnerability, exploit and payload refer to in software security.

    2) What could be the potential consequences of a buffer overflow attack?

    3) In the stack smashing attack, describe how to provide one input to overwrite EIP and inject shellcode at the same time.

3. In 2013, an international retail enterprise, Target, was compromised by attackers. The hackers intruded into the company's internal systems without raising any security alarms. They stole

credentials and credit card data of more than 70 million customers from a third-party vendor – an HVAC company. This vendor had more access than needed to execute its maintenance tasks on the Target network.

1) Write a threat model that would cover the Target data breach.

2) Describe the design principle related to this security incident.

4. The following program is designed to generate a random number. It takes a password as input, but always fails to generate a random number. Luckily, this program is vulnerable to a buffer overflow attack. Our goal is to leverage this advantage to generate a random number. Please describe one password that can achieve this. You do not need to give detailed input.

```
int CheckPassword() {
  char Password[100];
  printf("Enter your password:\n");
  gets(Password);
  return 0;
}

void GenerateRandomNumber() {
  printf("Your random number is %d\n", rand()%100);
}

int main(int argc, char* argv[]) {
  if(CheckPassword() == 1)
    GenerateRandomNumber();
  else
    printf("You don't have the permission to get a random number");
  return 0;
}
```

5. A developer writes the following program for user authentication for his system. However, this program is vulnerable to buffer overflow attack: the attacker could overwrite the hard-coded password to bypass the authentication.

```
char check_authentication(char *pwd) {
  char auth_flag = 'N';
  char Password[] = "qwertyu";
  char buffer[8];
  strcpy(buffer, pwd);
  if (strncmp(buffer, Password, 8) == 0)
    auth_flag = 'Y';
  return auth_flag;
}

int main(int argc, char* argv[]) {
  if(check_authentication(argv[1]) == 'Y')
    printf("Access Granted\n");
  else{
    printf("Access Denied\n");
  }
  return 0;
}
```

1) Please provide one input to achieve the attack.

2) To prevent this, the developer revises the function of check_authentication as below. However, it still has a buffer overflow vulnerability that enables the attacker to bypass the authentication without knowing the password. Please provide one input to achieve the attack.

```
char check_authentication(char *pwd) {
  char auth_flag = 'N';
  char buffer[8];
  strcpy(buffer, pwd);
  if (strncmp(buffer, "qwertyu", 8) == 0)
    auth_flag = 'Y';
  return auth_flag;
}
```